STATE OF PALESTINE · GENERAL SECRETARIAT OF THE CABINET

PALPASS

Master Architecture Dossier

Palestinian National Digital Identity and Civic Super-App. Sovereign e-governance, cryptographic field verification, and distributed public administration.

Principal systems architecture, application security, and civic full-stack specification for the production Next.js application.

Issued 4 October 2026
Emerald #064e3b · Gold #b45309 · Currency ILS

1. Meta-instructions and system identity

1.1 Operational role

This document is the ground-truth technical specification for PALPASS. An engineer working in this codebase operates as Principal Systems Architect, Chief Cryptographic Security Officer, and Lead Full-Stack Civic Engineer, in the jurisdiction of the State of Palestine, interfacing with the General Secretariat of the Palestinian Cabinet and the line ministries of Interior, Finance, Health, Transport, Higher Education, and Awqaf.

The core directive is to keep all 92 production build outputs working, follow the DESIGN.md tokens, keep financial mutations inside row-locked stored procedures, keep the production build free of remote font and script hosts, and refuse unauthenticated privilege escalation.

1.2 Non-negotiable guardrails

- **Financial immutability.** Do not bypass, alter, or mock `pay_bill_rpc`, `pay_violation_rpc`, `submit_border_permit_rpc`, `purchase_tender_brochure_rpc`, or `contribute_to_charity_rpc`. A client component must never update `wallets` directly.
- **Offline build.** `pnpm build` must exit 0 with no reference to fonts.googleapis.com, fonts.gstatic.com, or an unpinned public CDN.
- **Defense in depth.** A guest cannot commit a mutation. Unauthenticated clicks open `GuestAuthModal`. Fee-incurring and legally binding actions require `SovereignConfirmModal`.
- **Data isolation.** Private citizen tables (`wallets`, `family_registry`, `border_permits`, `citizen_cvs`) must not be opened with `SELECT USING (true)`.

2. System topology

The platform is a Next.js App Router application with Arabic (default, unprefixed) and English (`/en`) localization. Message files are paired. Middleware protects `/dashboard`, `/profile`, and `/admin`. Admin authorization reads `profiles.role` only.

The last production build generated **92 pages**. The table below is that inventory: 43 localized surfaces for Arabic and English (86) plus 6 platform outputs.

#	Path	Locale	Access	Duty
1	`/`	ar	Public	National landing
2	`/en`	en	Public	National landing
3	`/about`	ar	Public	Institutional overview
4	`/en/about`	en	Public	Institutional overview
5	`/news`	ar	Public	Official bulletin feed
6	`/en/news`	en	Public	Official bulletin feed
7	`/privacy`	ar	Public	Privacy policy
8	`/en/privacy`	en	Public	Privacy policy
9	`/terms`	ar	Public	Terms of service
10	`/en/terms`	en	Public	Terms of service
11	`/services`	ar	Public	Service catalog
12	`/en/services`	en	Public	Service catalog

#	Path	Locale	Access	Duty
13	/services/government	ar	Public page	Civil documents; mutation requires accreditation
14	/en/services/government	en	Public page	Civil documents; mutation requires accreditation
15	/services/bills	ar	Public page	Bill payment via pay_bill_rpc after confirm
16	/en/services/bills	en	Public page	Bill payment via pay_bill_rpc after confirm
17	/services/violations	ar	Public page	Fine payment via pay_violation_rpc after confirm
18	/en/services/violations	en	Public page	Fine payment via pay_violation_rpc after confirm
19	/services/border	ar	Public page	Crossing permit via submit_border_permit_rpc
20	/en/services/border	en	Public page	Crossing permit via submit_border_permit_rpc
21	/services/hajj	ar	Public page	Hajj file; guest clicks open GuestAuthModal
22	/en/services/hajj	en	Public page	Hajj file; guest clicks open GuestAuthModal
23	/services/licenses	ar	Public page	Trade and driving licenses
24	/en/services/licenses	en	Public page	Trade and driving licenses
25	/services/aid	ar	Public page	National assistance; gated submit
26	/en/services/aid	en	Public page	National assistance; gated submit
27	/services/aid-ration	ar	Public page	Ration entitlement
28	/en/services/aid-ration	en	Public page	Ration entitlement
29	/services/health-records	ar	Public page	MOH record and immunization table
30	/en/services/health-records	en	Public page	MOH record and immunization table
31	/services/healthcare	ar	Public page	Facility directory and referrals
32	/en/services/healthcare	en	Public page	Facility directory and referrals
33	/services/reports	ar	Public page	Incident report; guest clicks are intercepted
34	/en/services/reports	en	Public page	Incident report; guest clicks are intercepted
35	/services/justice	ar	Public page	Justice services
36	/en/services/justice	en	Public page	Justice services
37	/services/education	ar	Public page	Tawjihi and equivalency
38	/en/services/education	en	Public page	Tawjihi and equivalency
39	/services/tax-clearance	ar	Public page	Revenue clearance certificate
40	/en/services/tax-clearance	en	Public page	Revenue clearance certificate
41	/services/family	ar	Public page	Civil family booklet
42	/en/services/family	en	Public page	Civil family booklet
43	/services/complaints	ar	Public page	Cabinet complaint; accreditation required to submit
44	/en/services/complaints	en	Public page	Cabinet complaint; accreditation required to submit
45	/services/tenders	ar	Public page	Brochure purchase via purchase_tender_brochure_rpc
46	/en/services/tenders	en	Public page	Brochure purchase via purchase_tender_brochure_rpc
47	/services/cabinet-aid	ar	Public page	Humanitarian request; accreditation required
48	/en/services/cabinet-aid	en	Public page	Humanitarian request; accreditation required
49	/services/gazette	ar	Public	Official gazette, public read

#	Path	Locale	Access	Duty
50	/en/services/gazette	en	Public	Official gazette, public read
51	/services/jerusalem-fund	ar	Public page	Jerusalem support; accreditation required
52	/en/services/jerusalem-fund	en	Public page	Jerusalem support; accreditation required
53	/charity	ar	Public page	Donation via contribute_to_charity_rpc after confirm
54	/en/charity	en	Public page	Donation via contribute_to_charity_rpc after confirm
55	/jobs	ar	Public	Public employment listings
56	/en/jobs	en	Public	Public employment listings
57	/restaurants	ar	Public	Establishments directory
58	/en/restaurants	en	Public	Establishments directory
59	/restaurants/[id]	ar	Public	Establishment detail
60	/en/restaurants/[id]	en	Public	Establishment detail
61	/transport	ar	Public	Accredited transport hub
62	/en/transport	en	Public	Accredited transport hub
63	/transport/buses	ar	Public	Intercity coaches
64	/en/transport/buses	en	Public	Intercity coaches
65	/transport/taxis	ar	Public	Licensed taxi roster
66	/en/transport/taxis	en	Public	Licensed taxi roster
67	/documents	ar	Public page	Citizen document locker
68	/en/documents	en	Public page	Citizen document locker
69	/appointments	ar	Public page	MOH appointments; guest clicks are intercepted
70	/en/appointments	en	Public page	MOH appointments; guest clicks are intercepted
71	/auth/login	ar	Public auth	National ID sign-in
72	/en/auth/login	en	Public auth	National ID sign-in
73	/auth/register	ar	Public auth	Citizen registration
74	/en/auth/register	en	Public auth	Citizen registration
75	/auth/pending	ar	Public auth	Registration received
76	/en/auth/pending	en	Public auth	Registration received
77	/pending	ar	Public auth	Accreditation holding page
78	/en/pending	en	Public auth	Accreditation holding page
79	/dashboard	ar	Session	Middleware requires a signed-in citizen
80	/en/dashboard	en	Session	Middleware requires a signed-in citizen
81	/profile	ar	Session	Middleware requires a signed-in citizen
82	/en/profile	en	Session	Middleware requires a signed-in citizen
83	/profile/cv	ar	Session	ATS resume builder under /profile
84	/en/profile/cv	en	Session	ATS resume builder under /profile
85	/admin	ar	Admin	profiles.role must be admin; metadata role is ignored
86	/en/admin	en	Admin	profiles.role must be admin; metadata role is ignored

#	Path	Locale	Access	Duty
87	`/_not-found`	—	Asset	Not-found shell
88	`/apple-icon.png`	—	Asset	Apple touch icon
89	`/icon.png`	—	Asset	Application icon
90	`/manifest.webmanifest`	—	Asset	Web app manifest
91	`/api/verify`	—	Public API	GET field check, 20 requests per minute per IP
92	`/auth/callback`	—	Public auth	Root auth code exchange

Compiled count: 92. Desktop navigation is a single row from 1180px. Below that width, secondary links move into the off-canvas drawer. The crest and the citizen identity pill stay `shrink-0`.

3. Database schematics and concurrency

All entities live in PostgreSQL reached through the Supabase IPv4 session pooler. Wallet time is stored in `last_updated`. Financial deductions take `FOR UPDATE` on the wallet row before changing the balance.

3.1 Specified entities

Entity	Duty	Integrity
`profiles`	Demographic record and role	9-digit national ID, role citizen or admin
`wallets`	ILS balance	Non-negative balance, one row per citizen, `last_updated`
`border_permits`	Crossing clearance	Fee fixed at 170.00 inside the RPC; direct writes revoked from anon and authenticated
`public_tenders`	Cabinet procurement	Category works, supplies, consulting, or it_systems
`tender_purchases`	Brochure voucher	Unique citizen and tender; token prefix BOU-TND-
`citizen_cvs`	ATS resume	One active resume per citizen; professional or academic template

```
CREATE TABLE profiles (
  id UUID PRIMARY KEY REFERENCES auth.users(id) ON DELETE CASCADE,
  national_id VARCHAR(9) UNIQUE NOT NULL CHECK (national_id ~ '^\d{9}$'),
  full_name VARCHAR(255) NOT NULL,
  date_of_birth DATE NOT NULL,
  governorate VARCHAR(100) NOT NULL,
  role VARCHAR(50) NOT NULL DEFAULT 'citizen' CHECK (role IN ('citizen', 'admin')),
  status VARCHAR(50) NOT NULL DEFAULT 'pending' CHECK (status IN ('pending', 'active', 'rejected')),
  is_verified BOOLEAN NOT NULL DEFAULT false,
  created_at TIMESTAMPTZ NOT NULL DEFAULT NOW(),
  updated_at TIMESTAMPTZ NOT NULL DEFAULT NOW()
);

CREATE TABLE wallets (
  id UUID PRIMARY KEY DEFAULT gen_random_uuid(),
  user_id UUID UNIQUE NOT NULL REFERENCES profiles(id) ON DELETE CASCADE,
  balance NUMERIC(12,2) NOT NULL DEFAULT 0.00 CHECK (balance >= 0.00),
  currency VARCHAR(3) NOT NULL DEFAULT 'ILS',
  last_updated TIMESTAMPTZ NOT NULL DEFAULT NOW()
);

CREATE TABLE public_tenders (
  id UUID PRIMARY KEY DEFAULT gen_random_uuid(),
  tender_code TEXT UNIQUE NOT NULL,
  title TEXT NOT NULL,
  issuing_body TEXT NOT NULL,
  category TEXT NOT NULL CHECK (category IN ('works', 'supplies', 'consulting', 'it_systems')),
  brochure_price NUMERIC(10,2) NOT NULL DEFAULT 0.00,
  estimated_value NUMERIC(14,2) NOT NULL,
  submission_deadline TIMESTAMPTZ NOT NULL,
  status TEXT NOT NULL DEFAULT 'open' CHECK (status IN ('open', 'under_evaluation', 'awarded', 'cancelled')),
  details JSONB NOT NULL DEFAULT '{}'::jsonb,
  created_at TIMESTAMPTZ NOT NULL DEFAULT NOW()
);

CREATE TABLE border_permits (
  id UUID PRIMARY KEY DEFAULT gen_random_uuid(),
  user_id UUID NOT NULL REFERENCES profiles(id) ON DELETE CASCADE,
  permit_number VARCHAR(64) UNIQUE NOT NULL,
  crossing_point VARCHAR(50) NOT NULL,
  destination VARCHAR(100) NOT NULL,
  fee_amount NUMERIC(10,2) NOT NULL DEFAULT 170.00,
  payment_status VARCHAR(50) NOT NULL DEFAULT 'paid',
  status VARCHAR(50) NOT NULL DEFAULT 'under_security_clearance',
  created_at TIMESTAMPTZ NOT NULL DEFAULT NOW()
);

CREATE TABLE citizen_cvs (
  id UUID PRIMARY KEY DEFAULT gen_random_uuid(),
  user_id UUID UNIQUE NOT NULL REFERENCES profiles(id) ON DELETE CASCADE,
  template_type TEXT NOT NULL DEFAULT 'professional',
  personal_info JSONB NOT NULL DEFAULT '{}'::jsonb,
  summary TEXT,
  work_experience JSONB NOT NULL DEFAULT '[]'::jsonb,
  education JSONB NOT NULL DEFAULT '[]'::jsonb,
  skills JSONB NOT NULL DEFAULT '[]'::jsonb,
  certifications JSONB NOT NULL DEFAULT '[]'::jsonb,
  academic_publications JSONB NOT NULL DEFAULT '[]'::jsonb,
  languages JSONB NOT NULL DEFAULT '[]'::jsonb,
  signature_url TEXT,
  is_active BOOLEAN NOT NULL DEFAULT true,
  updated_at TIMESTAMPTZ NOT NULL DEFAULT NOW()
);
```

3.2 Atomic brochure purchase

The purchase routine validates the open tender, rejects a second purchase, locks the wallet with `FOR UPDATE`, debits `brochure_price`, writes `last_updated`, and returns a `BOU-TND-` voucher. Execution is granted only to `service_role`.

```
CREATE OR REPLACE FUNCTION purchase_tender_brochure_rpc(
  p_user_id UUID,
  p_tender_id UUID
) RETURNS JSONB
LANGUAGE plpgsql
SECURITY DEFINER
AS $$
DECLARE
  v_balance NUMERIC(10,2);
  v_price NUMERIC(10,2);
  v_status TEXT;
  v_token TEXT;
BEGIN
  SELECT brochure_price, status INTO v_price, v_status
  FROM public_tenders WHERE id = p_tender_id;
  IF NOT FOUND THEN
    RETURN jsonb_build_object('success', false, 'error', 'Tender not found');
  END IF;
  IF v_status <> 'open' THEN
    RETURN jsonb_build_object('success', false, 'error', 'Tender bidding is closed');
  END IF;
  IF EXISTS (
    SELECT 1 FROM tender_purchases
    WHERE user_id = p_user_id AND tender_id = p_tender_id
  ) THEN
    RETURN jsonb_build_object('success', false, 'error', 'Brochure already purchased');
  END IF;
  SELECT balance INTO v_balance FROM wallets
  WHERE user_id = p_user_id FOR UPDATE;
  IF v_balance < v_price THEN
    RETURN jsonb_build_object('success', false, 'error', 'Insufficient funds');
  END IF;
  UPDATE wallets
  SET balance = balance - v_price, last_updated = NOW()
  WHERE user_id = p_user_id;
  v_token := 'BOU-TND-' || upper(substr(md5(random()::text), 1, 8));
  INSERT INTO tender_purchases (user_id, tender_id, purchase_token, amount_paid)
  VALUES (p_user_id, p_tender_id, v_token, v_price);
  RETURN jsonb_build_object(
    'success', true,
    'purchase_token', v_token,
    'new_balance', v_balance - v_price
  );
END;
$$;
```

```
REVOKE ALL ON FUNCTION public.purchase_tender_brochure_rpc(UUID, UUID) FROM PUBLIC, anon, authenticated;
GRANT EXECUTE ON FUNCTION public.purchase_tender_brochure_rpc(UUID, UUID) TO service_role;
```

Procedure	anon EXECUTE	authenticated EXECUTE	service_role EXECUTE
pay_bill_rpc	false	false	true
pay_violation_rpc	false	false	true
contribute_to_charity_rpc	false	false	true
submit_border_permit_rpc	false	false	true

Procedure	anon EXECUTE	authenticated EXECUTE	service_role EXECUTE
purchase_tender_brochure_rpc	false	false	true

assert_actor_or_service returns immediately for a service_role JWT, rejects a null auth.uid() or an anon role, and rejects a caller whose identity does not match the target citizen.

4. Security posture

4.1 Response headers

Header	Value	Effect
X-Frame-Options	DENY	Blocks framing and clickjacking
X-Content-Type-Options	nosniff	Blocks MIME sniffing
Referrer-Policy	strict-origin-when-cross-origin	Limits referrer leakage
Permissions-Policy	camera=(), microphone=(), geolocation=(), browsing-topics=()	Disables those sensors

```
default-src 'self';
script-src 'self' 'unsafe-eval' 'unsafe-inline';
style-src 'self' 'unsafe-inline';
img-src 'self' blob: data: https://*.supabase.co;
font-src 'self' data:;
connect-src 'self' https://*.supabase.co https://*.pooler.supabase.com wss://*.supabase.co;
frame-ancestors 'none';
object-src 'none';
base-uri 'self';
```

4.2 Field verification

GET /api/verify accepts a 9-digit national_id or id, or a token. The handler uses the service role and returns only the masked projection. Missing, malformed, or inactive identities answer HTTP 404. The response is Cache-Control: no-store. The in-memory limit is 20 requests per 60 seconds per IP, then HTTP 429.

```
{
  "valid": true,
  "full_name": "المواطن المعتمد",
  "national_id_masked": "***-***-773",
  "governorate": "غزة",
  "status": "active",
  "is_verified": true,
  "issued_at": "2026-01-01T00:00:00Z"
}
```

5. Design tokens

Token	Value	Use
Sovereign emerald	#064e3b	Authority surfaces and smart cards
Interactive emerald	#047857	Buttons, active states, progress
Parchment	#fafaf9 / #f5f5f4	Paper backgrounds
Charcoal	#1c1917	Body text
Slate	#334155 / #64748b	Secondary text

Token	Value	Use
Sovereign gold	#b45309	Crests, stamps, official current steps
Seal gold	#d97706	Seal highlights
Flag red	#dc2626	Unpaid balances and destructive confirmation

Bright amber is reserved for warning alerts, including the pending-accreditation banner. `TatreezDivider` draws a low-opacity Palestinian cross-stitch rule between structural sections. Motion uses a 250ms ease of cubic-bezier(0.16, 1, 0.3, 1), and reduced-motion preferences remove the lift.

6. Ground-truth fixtures

6.1 Authority account

Field	Value
National ID	407926773
Password	PalPassAdmin#2026
Role / status	admin / active, verified
Wallet	Positive ILS balance
Tawjihi	Scientific stream, seat GAZ-2010-4079, 94.60%
Degree	Birzeit University, B.Sc. Computer Systems Engineering
License	Class B private, expiry 2030, blood type O+, 0 demerit points
Vehicle	Skoda Octavia 2.0 TDI (2023), plate 3-4079-90
Family book	Spouse and two dependent children
Jerusalem case	JLM-RES-SEED4079, Old City, Aqabat Al-Khaldiyya

6.2 Accredited citizen

National ID 556677889, role citizen, status active, verified. Records include a commercial taxi license and a confirmed Ministry of Health referral.

6.3 Institutional geography

- Hospitals: Al-Shifa Medical Complex (Gaza), Palestine Medical Complex (Ramallah), Rafidia Surgical Hospital (Nablus), Makassed Islamic Charitable Hospital (Jerusalem), Augusta Victoria / Al-Mutlaa (Jerusalem).
- Transport: Saraya Central Terminal (Gaza), Al-Bireh Central Station (Ramallah), Nablus Western Station.
- Utilities: Jerusalem District Electricity Co. (JDECO), Jerusalem Water Undertaking (JWU), Gaza Electricity Distribution Co. (GEDCO).